



ZAP by Checkmarx Scanning Report

Sites: <https://telem-edge.smartscreen.microsoft.com> <https://data-edge.smartscreen.microsoft.com> <https://nav-edge.smartscreen.microsoft.com> <https://www.bing.com> <https://copilot.microsoft.com> <http://localhost:3001>

Generated on Wed, 7 Jan 2026 18:58:12

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	8
Informational	8

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap. log file for details	21
Low	Warning		ZAP warnings logged - see the zap. log file for details	17
Info	Informational	http://localhost:3001	Percentage of responses with status code 1xx	4 %
Info	Informational	http://localhost:3001	Percentage of responses with status code 2xx	40 %
Info	Informational	http://localhost:3001	Percentage of responses with status code 3xx	14 %

Info	Informational	http://localhost:3001	Percentage of responses with status code 4xx	40 %
Info	Informational	http://localhost:3001	Percentage of endpoints with content type application/javascript	42 %
Info	Informational	http://localhost:3001	Percentage of endpoints with content type image/x-icon	7 %
Info	Informational	http://localhost:3001	Percentage of endpoints with content type text/css	7 %
Info	Informational	http://localhost:3001	Percentage of endpoints with content type text/html	28 %
Info	Informational	http://localhost:3001	Percentage of endpoints with method GET	100 %
Info	Informational	http://localhost:3001	Count of total endpoints	14
Info	Informational	http://localhost:3001	Percentage of slow responses	24 %
Info	Informational	https://copilot.microsoft.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://copilot.microsoft.com	Percentage of endpoints with content type application/json	100 %
			Percentage of endpoints	

Info	Informational	https://copilot.microsoft.com	with method GET	100 %
Info	Informational	https://copilot.microsoft.com	Count of total endpoints	1
Info	Informational	https://copilot.microsoft.com	Percentage of slow responses	100 %
Info	Informational	https://data-edge.smartscreen.microsoft.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://data-edge.smartscreen.microsoft.com	Percentage of endpoints with content type application/octet-stream	100 %
Info	Informational	https://data-edge.smartscreen.microsoft.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://data-edge.smartscreen.microsoft.com	Count of total endpoints	2
Info	Informational	https://data-edge.smartscreen.microsoft.com	Percentage of slow responses	100 %
Info	Informational	https://nav-edge.smartscreen.microsoft.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://nav-edge.smartscreen.microsoft.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	https://nav-edge.smartscreen.microsoft.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://nav-edge.smartscreen.microsoft.com	Count of total endpoints	1

Info	Informational	https://nav-edge.smartscreen.microsoft.com	Percentage of slow responses	36 %
Info	Informational	https://telem-edge.smartscreen.microsoft.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://telem-edge.smartscreen.microsoft.com	Percentage of endpoints with method POST	100 %
Info	Informational	https://telem-edge.smartscreen.microsoft.com	Count of total endpoints	1
Info	Informational	https://telem-edge.smartscreen.microsoft.com	Percentage of slow responses	25 %
Info	Informational	https://www.bing.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://www.bing.com	Percentage of endpoints with content type application/json	100 %
Info	Informational	https://www.bing.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://www.bing.com	Count of total endpoints	1
Info	Informational	https://www.bing.com	Percentage of slow responses	100 %

Alerts

Name	Risk Level	Number of Instances
CSP: script-src unsafe-eval	Medium	4
CSP: script-src unsafe-inline	Medium	4
CSP: style-src unsafe-inline	Medium	4
Big Redirect Detected (Potential Sensitive Information Leak)	Low	1

Cookie No HttpOnly Flag	Low	2
Cookie Without Secure Flag	Low	4
Cookie with SameSite Attribute None	Low	2
Cookie without SameSite Attribute	Low	5
Strict-Transport-Security Header Not Set	Low	6
Timestamp Disclosure - Unix	Low	2
X-Content-Type-Options Header Missing	Low	5
Authentication Request Identified	Informational	1
Content-Type Header Missing	Informational	1
Information Disclosure - Sensitive Information in URL	Informational	2
Information Disclosure - Suspicious Comments	Informational	6
Modern Web Application	Informational	Systemic
Re-examine Cache-control Directives	Informational	2
Session Management Response Identified	Informational	1
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	CSP: script-src unsafe-eval
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	script-src includes unsafe-eval.
URL	http://localhost:3001/login
Node Name	http://localhost:3001/login
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests

Other Info	script-src includes unsafe-eval.
URL	http://localhost:3001/robots.txt
Node Name	http://localhost:3001/robots.txt
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	script-src includes unsafe-eval.
URL	http://localhost:3001/sitemap.xml
Node Name	http://localhost:3001/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	script-src includes unsafe-eval.
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: script-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	
	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-

Evidence	backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	script-src includes unsafe-inline.
URL	http://localhost:3001/login
Node Name	http://localhost:3001/login
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	script-src includes unsafe-inline.
URL	http://localhost:3001/robots.txt
Node Name	http://localhost:3001/robots.txt
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	script-src includes unsafe-inline.
URL	http://localhost:3001/sitemap.xml
Node Name	http://localhost:3001/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	script-src includes unsafe-inline.
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: style-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	style-src includes unsafe-inline.
URL	http://localhost:3001/login
Node Name	http://localhost:3001/login
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	style-src includes unsafe-inline.
URL	http://localhost:3001/robots.txt
Node Name	http://localhost:3001/robots.txt
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	style-src includes unsafe-inline.
URL	http://localhost:3001/sitemap.xml
Node Name	http://localhost:3001/sitemap.xml
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://res.cloudinary.com https://*.cloudinary.com https://fixmo-backend-production.up.railway.app; font-src 'self' data:; connect-src 'self' https://fixmo-

	backend-production.up.railway.app https://res.cloudinary.com; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Other Info	style-src includes unsafe-inline.
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Low	Big Redirect Detected (Potential Sensitive Information Leak)
Description	The server has responded with a redirect that seems to provide a large response. This may indicate that although the server sent a redirect it also responded with body content (which may include sensitive details, PII, etc.).
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	
Evidence	
Other Info	Location header URI length: 6 [/login]. Predicted response size: 306. Response Body Length: 13,667.
Instances	1
Solution	Ensure that no sensitive information is leaked via redirect responses. Redirect responses should have almost no content.
Reference	
CWE Id	201
WASC Id	13
Plugin Id	10044

Low	Cookie No HttpOnly Flag
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: _C_Auth
Other Info	
URL	https://copilot.microsoft.com/c/api/user/eligibility

Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: MUID
Other Info	
Instances	2
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	Cookie Without Secure Flag
Description	A cookie has been set without the secure flag, which means that the cookie can be accessed via unencrypted connections.
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: _C_Auth
Other Info	
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: _EDGE_S
Other Info	
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: _EDGE_V
Other Info	
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	

Evidence	Set-Cookie: MUIDB
Other Info	
Instances	4
Solution	Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.
Reference	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html
CWE Id	614
WASC Id	13
Plugin Id	10011

Low	Cookie with SameSite Attribute None
Description	A cookie has been set with its SameSite attribute set to "none", which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: __cf_bm
Other Info	
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: MUID
Other Info	
Instances	2
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility

Method	GET
Attack	
Evidence	Set-Cookie: _C_Auth
Other Info	
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: _C_ETH
Other Info	
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: _EDGE_S
Other Info	
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: _EDGE_V
Other Info	
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	Set-Cookie: MUIDB
Other Info	
Instances	5
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054
Low	Strict-Transport-Security Header Not Set

Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	
Other Info	
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})
Method	POST
Attack	
Evidence	
Other Info	
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})
Method	POST
Attack	
Evidence	
Other Info	
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3
Node Name	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3 ()({userAgent,redirectChain:{source,chain:[]},identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},destination:{uri,ip},type,forceServiceDetermination,correlatio...)

Method	POST
Attack	
Evidence	
Other Info	
URL	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3
Node Name	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3 () ({executionTime,random,samplingRates:{evaluateModel,serverCall},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},correlationId,identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},userAgent,events:[{\$type,nam...})
Method	POST
Attack	
Evidence	
Other Info	
Instances	6
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	1767783371
Other Info	1767783371, which evaluates to: 2026-01-07 18:56:11.
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	1767783371
Other Info	1767783371, which evaluates to: 2026-01-07 18:56:11.

Instances	2
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:

Node Name	{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUri,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}}
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3
Node Name	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3 ()({userAgent,redirectChain:{source,chain:[]},identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUri,edgeSettings,customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},destination:{uri,ip},type,forceServiceDetermination,correlatio...)
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	5
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://localhost:3001/login?password=ZAP&username=ZAP
Node Name	http://localhost:3001/login (password,username)
Method	GET
Attack	
Evidence	password
Other Info	userParam=username userValue=ZAP passwordParam=password referer=http://localhost:3001/login
Instances	1

Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Content-Type Header Missing
Description	The Content-Type header was either missing or empty.
URL	http://localhost:3001/login?password=ZAP&username=ZAP
Node Name	http://localhost:3001/login (password,username)
Method	GET
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure each page is setting the specific and appropriate content-type value for the content being delivered.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
CWE Id	345
WASC Id	12
Plugin Id	10019

Informational	Information Disclosure - Sensitive Information in URL
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and most organizational compliance policies. You can configure the list of strings for this check to add or remove values specific to your environment.
URL	http://localhost:3001/login?password=ZAP&username=ZAP
Node Name	http://localhost:3001/login (password,username)
Method	GET
Attack	
Evidence	password
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern: pass password
URL	http://localhost:3001/login?password=ZAP&username=ZAP
Node Name	http://localhost:3001/login (password,username)
Method	GET
Attack	
Evidence	username
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern: user username
Instances	2
Solution	Do not pass sensitive information in URIs.

Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://localhost:3001/_next/static/chunks/_app-pages-browser_node_modules_next_dist_client_dev_noop-turbopack-hmr_js.js
Node Name	http://localhost:3001/_next/static/chunks/_app-pages-browser_node_modules_next_dist_client_dev_noop-turbopack-hmr_js.js
Method	GET
Attack	
Evidence	later
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "// The Turbopack HMR client can't be properly omitted at the moment (WEB-1589),\n// so instead we remap its import to this file ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3001/_next/static/chunks/app-pages-internals.js
Node Name	http://localhost:3001/_next/static/chunks/app-pages-internals.js
Method	GET
Attack	
Evidence	Admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "//# sourceURL=[module]\n//# sourceMappingURL=data:application/json;charset=utf-8;base64,eyJ2ZXJzaW9uIjozLCJmaWxlIjoieGFwcC1wYWdl", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3001/_next/static/chunks/app/login/page.js
Node Name	http://localhost:3001/_next/static/chunks/app/login/page.js
Method	GET
Attack	
Evidence	Admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "//# sourceURL=[module]\n//# sourceMappingURL=data:application/json;charset=utf-8;base64,eyJ2ZXJzaW9uIjozLCJmaWxlIjoieGFwcC1wYWdl", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3001/_next/static/chunks/main-app.js?v=1767783367359
Node Name	http://localhost:3001/_next/static/chunks/main-app.js (v)
Method	GET
Attack	
Evidence	later
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "//# sourceMappingURL=add-base-path.js.map\n\n\n\n // Wrapped in an IIFE to avoid polluting the global scope\n ;\n (fun", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3001/_next/static/chunks/polyfills.js
Node Name	http://localhost:3001/_next/static/chunks/polyfills.js

Method	GET
Attack	
Evidence	from
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "//github.com/zloirock/core-js/blob/v3.38.1/LICENSE",source:"https://github.com/zloirock/core-js"})), nt=function(t,e){return rt["", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3001/_next/static/chunks/webpack.js?v=1767783367359
Node Name	http://localhost:3001/_next/static/chunks/webpack.js (v)
Method	GET
Attack	
Evidence	from
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "// inherit from previous dispose call", see evidence field for the suspicious comment/snippet.
Instances	6
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	
Evidence	<script src="/_next/static/chunks/main-app.js" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	
Evidence	<script src="/_next/static/chunks/main-app.js?v=1767783366702" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3001/login
Node Name	http://localhost:3001/login
Method	GET
Attack	

Evidence	<script src="/_next/static/chunks/main-app.js?v=1767783367532" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3001/robots.txt
Node Name	http://localhost:3001/robots.txt
Method	GET
Attack	
Evidence	<script src="/_next/static/chunks/main-app.js?v=1767783367360" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:3001/sitemap.xml
Node Name	http://localhost:3001/sitemap.xml
Method	GET
Attack	
Evidence	<script src="/_next/static/chunks/main-app.js?v=1767783367359" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	
Other Info	

Instances	2
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	https://copilot.microsoft.com/c/api/user/eligibility
Node Name	https://copilot.microsoft.com/c/api/user/eligibility
Method	GET
Attack	
Evidence	MUIDB
Other Info	cookie:MUIDB cookie:__cf_bm cookie:MUID cookie:_EDGE_S
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET

Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko
Evidence	
Other Info	
URL	http://localhost:3001/
Node Name	http://localhost:3001/
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3739.0 Safari/537.36 Edg/75.0.109.0
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104